



Use After Free



Bối cảnh (Context)

Ứng dụng C++ quản lý đội hình chiến binh cho phép bạn tạo chiến binh mới, nâng cấp họ, và giải tán (xóa) chiến binh khỏi đội hình. Khi giải tán, bộ nhớ của chiến binh đó sẽ được trả lại cho hệ thống.

Tuy nhiên, khi gọi menu "Xem thông tin chiến binh đã giải tán", hệ thống vẫn in ra dữ liệu mà không hề báo lỗi, vì con trỏ (pointer) vẫn trỏ về vị trí cũ.



Mục tiêu (Objective)

- **Nhiệm vụ:** Khai thác lỗi vùng nhớ để thực thi shellcode hoặc gọi hàm ẩn chiếm quyền.
- **Vấn đề / Lỗi hỏng: Use-After-Free (UAF) trên Heap.** Ứng dụng giải phóng vùng nhớ nhưng không xóa con trỏ cũ (Dangling Pointer). Hacker có thể cấp phát một cấu trúc dữ liệu mới (ví dụ dạng chuỗi string) có kích thước y hệt vùng nhớ vừa giải phóng, ghi đè dữ liệu mong muốn (như địa chỉ con trỏ hàm). Khi ứng dụng gọi lại con trỏ cũ, nó sẽ thực thi vùng dữ liệu do hacker vừa chèn vào.
- **Flag:** Chuyển hướng luồng thực thi thành công.



Gợi ý (Hints)

- Hãy tạo một đối tượng A, rồi giải phóng đối tượng A.
- Tạo một đối tượng B (có cùng size) với dữ liệu đã được tính toán kỹ. Hệ thống sẽ cấp phát vùng nhớ cũ của A cho B.
- Gọi một hàm từ con trỏ của A, thực chất là gọi code từ dữ liệu B.